

1. Cluster di attività di esercizio 1: Utilizzo di *Powershell*

1.1. Ambito operativo e obiettivi

Le attività di questo cluster di attività è l'analisi tecnica ha lo scopo di esaminare ed esplorare le funzionalità di Windows PowerShell applicate alla gestione dei sistemi e al monitoraggio della sicurezza di rete. Nel dettaglio, gli obiettivi operativi dell'attività comprendono:

- Accesso e confronto interfacce, tra cui la valutazione e analisi comparativa tra il software di linea di comando *Prompt dei Comandi*, o `cmd.exe` e la console di linea di comando *Windows PowerShell*, o `powershell.exe`.
- Analisi dei *Cmdlet* e degli *alias*, tra cui l'identificazione dei comandi nativi di *PowerShell (cmdlet)* strutturati secondo la sintassi Verbo-Nome e verifica delle corrispondenze tramite alias, tra cui il comando `Get-Alias`.
- Ispezione di rete avanzata, tra cui le attività d'uso del software `netstat` per il tracciamento delle connessioni attive (TCP/IP), l'esame delle tabelle di routing, tramite il comando `netstat -r` e la correlazione tra socket di rete e identificativi di processo (PID) mediante privilegi elevati, tramite il comando `netstat -abno`.
- Verifica e correlazione dei processi, tra cui la mappatura dei PID rilevati tramite `netstat` con i processi di sistema attivi sul *Task Manager* per l'individuazione di comportamenti o servizi anomali.
- Automazione e gestione del sistema, tra cui l'esecuzione di comandi di manutenzione e pulizia, tra cui `clear-recyclebin` per la cartella di sistema `$Recycle.Bin`.

1.2. Contesto e scenario

Windows PowerShell rappresenta un framework fondamentale per l'amministrazione di sistema e la gestione della configurazione basato su un motore di scripting e una console di comando ad alte prestazioni. Integrandosi nativamente con il sistema operativo Windows, PowerShell consente di automatizzare compiti complessi sia in locale sia su vaste architetture distribuite.

Dal punto di vista dell'analisi e della cybersicurezza, PowerShell si attesta come uno strumento duale. In un lato, permette agli analisti in chiave difensiva di effettuare rapidamente attività di incident response, auditing di sistema, monitoraggio delle connessioni di rete in tempo reale e deployment centralizzato di policy o soluzioni di sicurezza, mentre dall'altro, in chiave di minaccia (*Threat Analysis*), essendo un tool nativo e fidato del sistema operativo, è un possibile vettore di attacco per tecniche di tipo *Living off the Land* (LotL).

1.3. Parte 1 e 2: Accesso alla console di Powershell e esplorazione del prompt di comandi

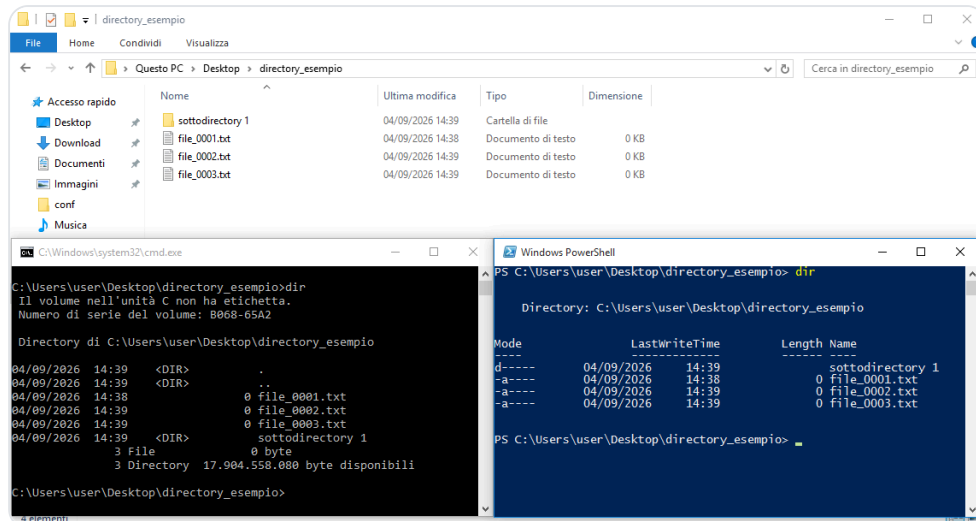
Per le attività del presente paragrafo si sono aperti la finestra del software di linea di comando *Prompt dei Comandi*, o `cmd.exe`, e la finestra del software di "linea di comando" *Powershell*, o `powershell.exe` tramite il pannello *File* dell'interfaccia *Ribbon* di *Windows Explorer*.



Quali sono gli output del comando `dir`?

Eseguendo il comando `dir` in entrambe le interfacce, si ottiene l'elenco dei file e delle sottodirectory presenti nella cartella corrente, sebbene la formattazione grafica dell'output risulti differente tra le due console per via di operazioni differenti invocate:

- nel *Prompt dei Comandi*, o `cmd.exe`, il comando `dir`, essendo interno e nativo, come in MS-DOS, restituisce un prospetto dettagliato con data, ora, dimensione e nome dei file o cartelle.
- In *Windows PowerShell*, o `powershell.exe`, il comando `dir` è un puntatore, o *alias* al comando `Get-ChildItem`, il quale ritorna la struttura degli oggetti file sotto forma di tabella strutturata con le colonne "Mode", "LastWriteTime", "Length" e "Name".



Ci si sposta ora all'analisi dei comandi `ping`, `cd` e `ipconfig`

? Quali sono i risultati?

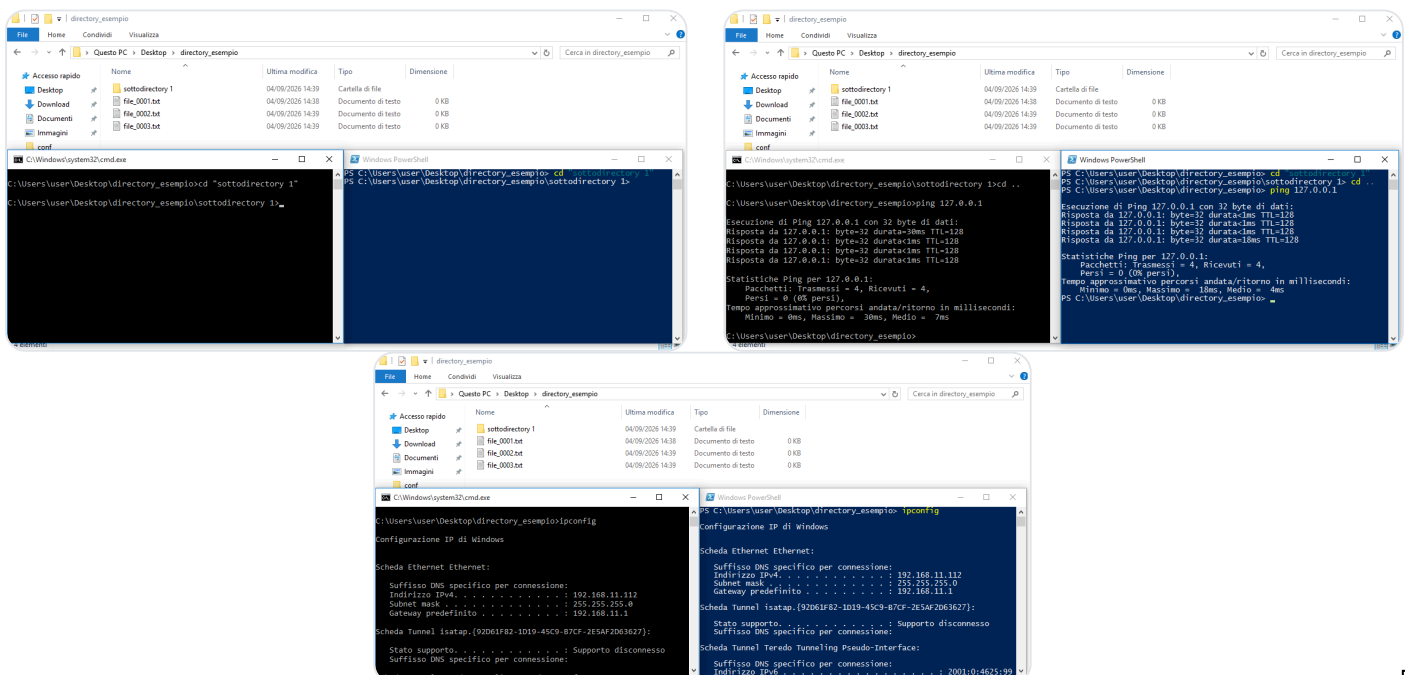
Relativamente al comando `cd`, si sono notati i seguenti punti:

- Nel *Prompt dei Comandi*, o `cmd.exe` è un comando interno nativo per la gestione del percorso.
- In Windows PowerShell, o `powershell.exe` il comando `cd` è un puntatore, o *alias* al comando `Set-Location`, mantenuto per garantire la compatibilità con la sintassi tradizionale.

Eseguendo `cd "sottodirectory 1"` e successivamente `cd ..`, entrambe le console aggiornano correttamente il percorso corrente del prompt.

Relativamente al comando `ping`, si è notato che in entrambe le console, l'esecuzione di `ping 127.0.0.1` richiama l'eseguibile binario di sistema `ping.exe`. L'output invia 4 pacchetti dati all'indirizzo di loopback locale e restituisce le medesime statistiche su tempi di risposta e pacchetti ricevuti/persi.

Relativamente al comando `ipconfig`, si è notato che in entrambe le console è invocata l'utilità esterna `ipconfig.exe`, il quale mostra la configurazione IP delle schede di rete, fornendo un output pressoché identico.



1.4. Parte 3: Esplorazione dei *cmdlet*.

? Qual è il comando PowerShell per dir?

Nel software di linea di comando, il comando analogo a `dir` è `Get-ChildItem`. Tramite la direttiva `-Recurse`, il comando esegue in modo ricorsivo l'indicizzazione delle sottocartelle a partire dal percorso specificato nell'argomento `-Path` o `-LiteralPath`.



```
Windows PowerShell
Copyright (C) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

PS C:\Users\User> Get-Alias dir

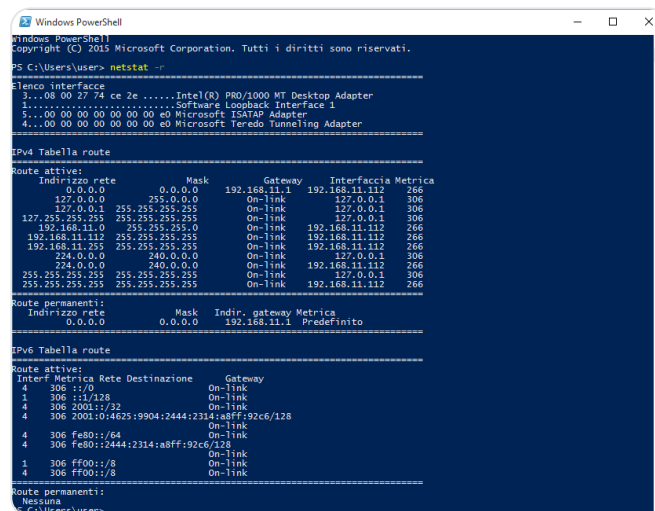
CommandType      Name
-----
Alias             dir -> Get-ChildItem

PS C:\Users\User>
```

1.5. Parte 4: Esplorare il comando netstat usando PowerShell.

? Qual è il gateway IPv4?

Dall'output del comando `netstat -r`, il gateway IPv4 rilevato è `192.168.11.1`, il quale è associato alla rotta predefinita `0.0.0.0`.



```
Windows PowerShell
Copyright (C) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

PS C:\Users\User> netstat -r

=====
Elenco interfacce
3...08 00 27 74 ce 2e .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
5...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
4...00 00 00 00 00 00 e0 Microsoft Teredo Tunneling Adapter
=====

IPv4 Tabella route

Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia Metrica
-----
0.0.0.0             0.0.0.0    192.168.11.1 192.168.11.12 266
127.0.0.1           255.255.255.255 On-link      127.0.0.1     306
127.255.255.255     255.255.255.255 On-link      127.0.0.1     306
192.168.11.12       255.255.255.255 On-link      192.168.11.12 266
192.168.11.255     255.255.255.255 On-link      192.168.11.12 266
224.0.0.0           240.0.0.0   On-link      127.0.0.1     306
255.255.255.255     255.255.255.255 On-link      192.168.11.12 266
255.255.255.255     255.255.255.255 On-link      192.168.11.12 266

Route permanenti:
Indirizzo rete      Mask      Indir. gateway Metrica
-----
0.0.0.0             0.0.0.0    192.168.11.1 Predefinito

IPv6 Tabella route

Route attive:
Interf Metrica Rete Destinazione Gateway
-----
4 306 :1/0 On-link
1 306 :1/128 On-link
4 306 2001::32 On-link
4 306 2001:0:4625:9904::2444:2314:a8ff:92c6/128 On-link
4 306 fe80::64 On-link
4 306 fe80::2444:2314:a8ff:92c6/128 On-link
1 306 ff00::8 On-link
4 306 ff00::8 On-link

Route permanenti:
Nessuna

PS C:\Users\User>
```

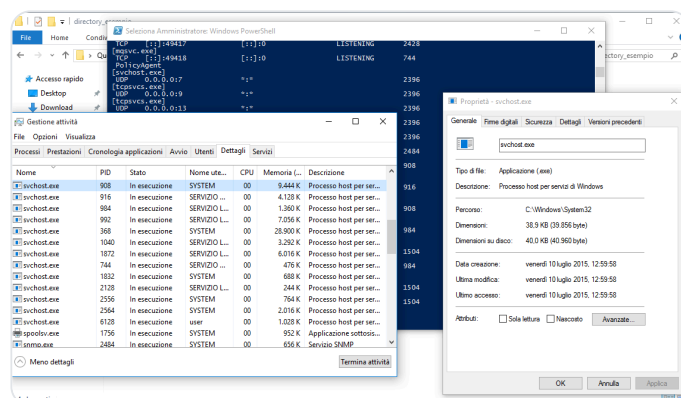
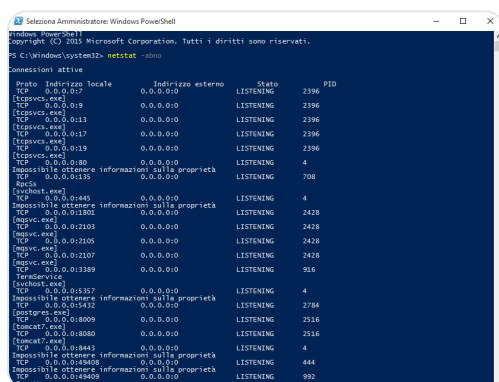
L'analisi si sposta sulle attività di individuazione degli identificativi (PID) dei processi con una sessione attiva di trasmissione dati telecomunicativi tramite il comando `netstat -abno`.



Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Dalla scheda Dettagli di Gestione Attività e dalla finestra Proprietà del processo selezionato, in questo caso PID 908, o `svchost.exe` è possibile ottenere le seguenti informazioni analitiche:

- Dalla scheda "Dettagli" (Gestione Attività), è possibile ottenere il nome del processo (`svchost.exe`, nel caso di analisi), l'identificatore del processo o PID (908, nel caso di analisi), lo stato del processo ("In esecuzione", nel caso di analisi), il nome utente esecutore del processo (`SYSTEM`, nel caso di analisi), il livello d'uso di risorse CPU e RAM, e la descrizione breve del processo
- Dalla scheda "Proprietà", è possibile ottenere il nome e il percorso dell'eseguibile del processo (`C:\Windows\System32` e `svchost.exe`, nel caso di analisi), il tipo di file e dimensioni (38,9 KB / 40,0 KB, nel caso di analisi), indicatori timestamp di Data e ora di creazione, ultima modifica e ultimo accesso, firme digitali e dettagli aggiuntivi (tramite le altre schede), tra cui informazioni sul publisher/produttore e versione del file e integrità del certificato digitale



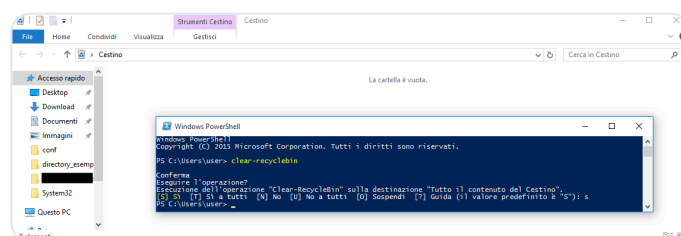
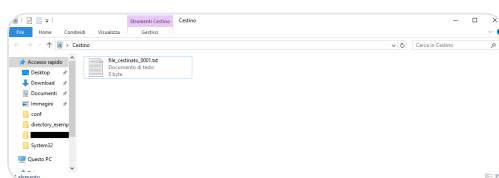
1.6. Parte 5: Svuotare il cestino usando PowerShell.

L'analisi si sposta sul comportamento del cestino, ovvero della cartella di sistema `$Recycle.Bin`, in concomitanza del comando `clear-recyclebin`.



Cosa è successo ai file nel Cestino?

Invocando il comando `clear-recyclebin`, o `Clear-RecycleBin`, il contenuto del cestino, ovvero della cartella di sistema `$Recycle.Bin` è svuotato e i file, ovvero i riferimenti a questi, sono cancellati



1.7. Riflessioni

Essendo *Powershell* sviluppato per l'automazione delle attività e la gestione della configurazione dei servizi del sistema operativo, si rileva anche uno strumento di analisi di sicurezza, particolarmente con i seguenti comandi:

- `Get-NetTCPConnection` e `Test-NetConnection`, con i quali si ottengono rispettivamente tutte le connessioni TCP correnti, gli IP remoti e i PID associati, e l'indice di connettività di rete verso un host e una porta. Tra i casi d'uso di questi comandi ci sono le attività di identificazione delle connessioni verso iP e dei domini *Command & Control* (C2) esterni;
- `Resolve-DnsName` (analogo al comando `nslookup`), `Get-DnsClient` e `Set-DnsClientServerAddress`, per diagnostica, gestione e configurazione delle impostazioni DNS della rete. Tra i casi d'uso di questi comandi ci sono le attività di identificazione di attacchi al DNS e le attività di identificazione delle connessioni verso iP e dei domini *Command & Control* (C2) esterni;
- `Get-WinEvent`, con i quali è possibile l'accesso e filtro degli eventi di log di Windows. Questi possono essere filtrati tramite un oggetto `PSObject` o `HashTable` passato all'argomento `-FilterHashtable`. Tra i casi d'uso di questi comandi ci sono le attività di analisi dei log di eventi e di *Threat Hunting* su eventi sospetti.
- `Get-LocalUser` e `Get-LocalGroupMember`, per l'enumerazione degli utenti e gruppi registrati sulla macchina. Tra i casi d'uso di questi comandi ci sono le attività di *audit* degli utenti e delle relative *ACL*;
- `Get-ADUser`, `Get-ADGroupMember` e `Get-ADGroup`, per l'enumerazione degli utenti e gruppi registrati in un ambiente Windows con *Active Directory*. Tra i casi d'uso di questi comandi ci sono le attività di *audit* degli utenti e delle relative *ACL* in ambienti *Windows Active Directory*;
- `Get-FileHash` e `Get-AuthenticodeSignature`, il quali ritornano rispettivamente l'hash SHA256 (tramite il *flag* `-Algorithm SHA256`) e la firma digitale del determinato file. Tra i casi d'uso di questi comandi ci sono le attività di riconoscimento dei *software malware*, ritornando possibili indicatori di compromissione (IoC).